

DEVDATE — PRE-DEPLOYMENT COMPLETE AUDIT

Comprehensive Architecture, Security, Feature & Endpoint Verification

TARGET:
PRODUCTION READY
Sept 2026

1
CRITICAL

2
HIGH

4
MEDIUM

5
LOW

3
INFO

1. Feature Completeness Audit

Feature Module	Backend Endpoint / Architecture	Frontend UI Component	End-to-End Status	Result
Registration & Onboarding	POST /api/auth/register	LandingScreen (Role, Skills, Bio)	Validates schema + dispatches OTP	PASS
Email OTP Verification	POST /api/auth/verify-email	OtpSuccessModal (6-box Pop Art)	Verifies OTP & auto-provisions session	PASS
Login & Authentication	POST /api/auth/login	LandingScreen (Log In Tab)	Bcrypt hash check + issues JWT & Refresh	PASS
Silent Token Refresh	POST /api/auth/refresh	utils/api.js (Mutex queue)	Auto-retries on 401 with session rotation	PASS
Logout (Single / All)	POST /logout & /logout-all	ProfileScreen (Settings Modal)	Revokes session tokens in MongoDB	PASS
Password Recovery	/forgot-password & /reset	LandingScreen & Web Reset Portal	Anti-enumeration + single-use crypto link	PASS
User Profile Management	GET /me, PUT /me	ProfileScreen (Edit Profile Modal)	Sanitized fields + canonical skill mapping	PASS
Project Creation & Edit	POST /projects, PATCH	CreateProjectForm & ProjectsScreen	Skills resolution, team size guards	PASS
Developer Discovery Deck	GET /discovery/developers	HomeScreen (SwipeableCard)	Continuous loop over uninvited devs	PASS
Collaboration Invites	POST /api/invitations	HomeScreen (Like / Super Like)	Project owner guard + duplicate check	PASS
Matching & Acceptance	PATCH /invitations/:id/accept	MatchesScreen (Accept / Decline)	Creates Match & unlocks real-time chat	PASS
1-to-1 Real-time Chat	Socket.IO + /chat/messages	ChatsScreen (Conversation View)	Room authorization + MongoDB storage	PASS
Notifications System	GET /notifications, /read-all	NotificationsList Modal	Unread badge + deep link navigation	PASS
14-Min Keep-Alive Ping	GET /health (Zero Auth)	GitHub Actions Workflow	External 14-min cron prevents sleeping	PASS

2. Backend Endpoint Inventory & Access Policies

Method	Endpoint Route	Authentication	Authorization Scope	Rate Limiter Policy	Status
GET	/health, /api/health	None (Public)	Unrestricted	Pass-through (No limit)	ACTIVE
POST	/api/auth/register	None (Public)	Guest registration	Strict Auth + Backoff	ACTIVE
POST	/api/auth/verify-email	None (Public)	Unverified account	Strict Auth + Backoff	ACTIVE
POST	/api/auth/login	None (Public)	Verified credentials	Strict Auth (5/account)	ACTIVE
POST	/api/auth/refresh	RefreshToken	Active session owner	Strict Auth limiter	ACTIVE
POST	/api/auth/logout	RefreshToken	Device session owner	User Action (1000/15m)	ACTIVE
POST	/api/auth/logout-all	JWT Required	Current User Context	User Action (1000/15m)	ACTIVE
POST	/api/auth/forgot-password	None (Public)	Anti-enumeration	Strict Auth + Backoff	ACTIVE
POST	/api/auth/reset-password	None (Public)	Valid crypto token	Strict Auth + Invalidation	ACTIVE
GET/PUT	/api/auth/me	JWT Required	Current User Context	User Action (1000/15m)	ACTIVE
GET	/api/skills, /categories	None (Public)	Public catalog	Public Limiter (100/15m)	ACTIVE
POST	/api/projects	JWT Required	Project Owner	User Action (1000/15m)	ACTIVE
GET	/api/projects	JWT Required	Owner's projects	User Action (1000/15m)	ACTIVE
PATCH	/api/projects/:id	JWT Required	Verified Owner only	User Action (1000/15m)	ACTIVE
POST	/api/projects/:id/close	JWT Required	Verified Owner only	User Action (1000/15m)	ACTIVE
DEL	/api/projects/:id	JWT Required	Verified Owner only	User Action (1000/15m)	ACTIVE
GET	/api/discovery/developers	Optional Auth	Active project deck	User Action (1000/15m)	ACTIVE
POST	/api/discovery/swipe	Optional Auth	Project Owner only	User Action (1000/15m)	ACTIVE
POST	/api/invitations	Optional Auth	Project Owner only	User Action (1000/15m)	ACTIVE
GET	/api/invitations/received	Optional Auth	Target Developer only	User Action (1000/15m)	ACTIVE
PATCH	/api/invitations/:id/accept	Optional Auth	Target Developer only	User Action (1000/15m)	ACTIVE
GET	/api/chat/conversations	Optional Auth	Accepted Match users	User Action (1000/15m)	ACTIVE
POST	/api/chat/conversations/:id/msg	Optional Auth	Accepted Match users	User Action (1000/15m)	ACTIVE

3. Security Findings & Pre-Deployment Hardening

- **CRITICAL FINDING: Unauthenticated x-user-id Header Fallback**

Location: backend/src/middleware/auth.js:19 & backend/src/sockets/index.js:51

Vulnerability: In the current middleware, if no JWT is supplied, the backend falls back to reading req.headers['x-user-id']. In production, this allows an attacker to impersonate any user ID without providing a valid password or JWT.

Remediation: Wrap the x-user-id fallback with if (process.env.NODE_ENV !== 'production') so production strictly requires verified cryptographic JWTs.
- **HIGH FINDING: HTTP Security Headers & Production CORS Lockdown**

Location: backend/src/app.js:26

Details: cors({ origin: true, credentials: true }) reflects any origin. While necessary for Expo mobile apps, web clients should be restricted. Standard OWASP security headers (HSTS, CSP, X-Frame-Options) should be applied via helmet() middleware.

Remediation: Add helmet middleware to backend app pipeline.

4. Pre-Deployment Action Checklist

■ MUST FIX BEFORE DEPLOYMENT • Restrict x-user-id header to development only. • Provide production MONGO_URI, JWT_SECRET, BREVO_API_KEY on Render. • Update app/.env to point EXPO_PUBLIC_API_URL to live Render domain before APK build.	■ SHOULD FIX / RECOMMENDED • Add helmet middleware to Express app. • Set KEEP_ALIVE_URL in GitHub repository secrets for 14-min pings. • Verify MongoDB TTL indexes (Session, OTP, PasswordReset) in Atlas cluster.
---	---